

AI & ML Governance + Evaluation Command Centre

PROTOTYPE

A scalable governance model for AI risk — risk appetite, KRIs, and accountable decisions at every stage.

Product brief | Mahesh Kumar | June 2026

THE PROBLEM

Most AI governance programs conflate inherent risk (what could go wrong before any controls) with residual risk (what remains after). Without that distinction, a High-risk result could mean a dangerous system or a well-controlled one with high baseline exposure — and governance can't tell the difference. Scores accumulate; no one is authorized to act on them.

THE OPPORTUNITY

Build enterprise-wide architecture that captures both layers explicitly: characterise inherent risk for every AI system before controls are assessed, then measure residual risk through structured control evaluation. The gap between the two is the governance story — where risk appetite is being met, and where it isn't.

SCOPE

In scope: a registry of AI systems with inherent risk characterisation (autonomy, reversibility, data sensitivity, customer impact); residual risk assessment across six control domains; a governance layer that converts the gap into an accountable action, owner, and SLA. Out of scope (for now): live model hosting and automated remediation — these sit on the roadmap below.

HOW IT WORKS — FROM RISK APPETITE TO ACCOUNTABLE DECISION

1. Characterise

Map inherent risk before controls: autonomy level, action reversibility, data sensitivity, and customer impact.

2. Assess

Residual risk: scored control by control across six domains against OSFI, PIPEDA, and Treasury Board requirements.

3. Evaluate

Ongoing agent and model behavior checks — groundedness, accuracy, bias — compared version-over-version.

4. Decide

Inherent → residual gap maps to a governance action: accept, escalate, or block — named owner, approver, SLA.

BUILT FOR INHERENT → RESIDUAL RISK — NOT JUST A SCORE

LEVEL 1 — INHERENT RISK

Four-factor characterisation before any controls: autonomy level, action reversibility, data sensitivity, and customer impact. The highest single factor drives the band — it can't be averaged away.

LEVEL 2 — RESIDUAL RISK

Every control individually scored Met / Partial / Not Met, tagged by severity (Critical → Low) and traced to a specific regulatory clause. The gap between inherent and residual risk is the governance story.

LEVEL 3 — EVIDENCE & TREND

Every Not Met or Partial control carries a remediation owner and target date, rolled into a portfolio-wide findings log. Each system also has a score history, so a reviewer can see the trend, not just the current state.

Example: the Underwriting Decision Engine is fully autonomous (Critical inherent risk). Even with some controls passing, its residual risk is still High Risk. That gap — Critical inherent, High residual — is the governance signal: controls exist but aren't closing enough of the inherent exposure to reach an acceptable residual level.

ROADMAP

NOW — FOUNDATION

Risk-based registry, 6 domains, control-level scoring per question
Severity & citation per control; severity-weighted risk rollup
Findings log + remediation owner and target date per gap
Score history per system & overdue recertification queue

NEXT — STRENGTHEN

Persistent system of record — durable storage, not session-only
Role-based access (risk owner, approver, governance lead)
Calibration against enterprise risk appetite and KRI thresholds
Product KPIs: adoption, time-to-remediate, decisions followed
Exportable reports for risk committees and audit

LATER — SCALE

Coverage across all business lines, not just pilot systems
Tiered governance by risk level — lighter touch for low-risk systems
Integration with existing model risk (e.g., E-23) inventory and processes
Self-service onboarding for new AI systems as they're built

Live demo: ai-ml-governance-app.streamlit.app | Portfolio: github.com/mkumar84

Working prototype built to explore this problem space. Evaluation runs and scoring rubrics are illustrative; not a substitute for formal regulatory advice.